

Validation of file extension with null byte bypass

PRACTITIONER

Tipo de explotación

Path Traversal al cargar una imagen del servidor.

La aplicación valida que el nombre de archivo proporcionado termine con la extensión de archivo esperada.

Objetivo

Encontrar la vulnerabilidad Path Traversal de las rutas en la visualización de imágenes de productos.

Explicación técnica de la vulnerabilidad

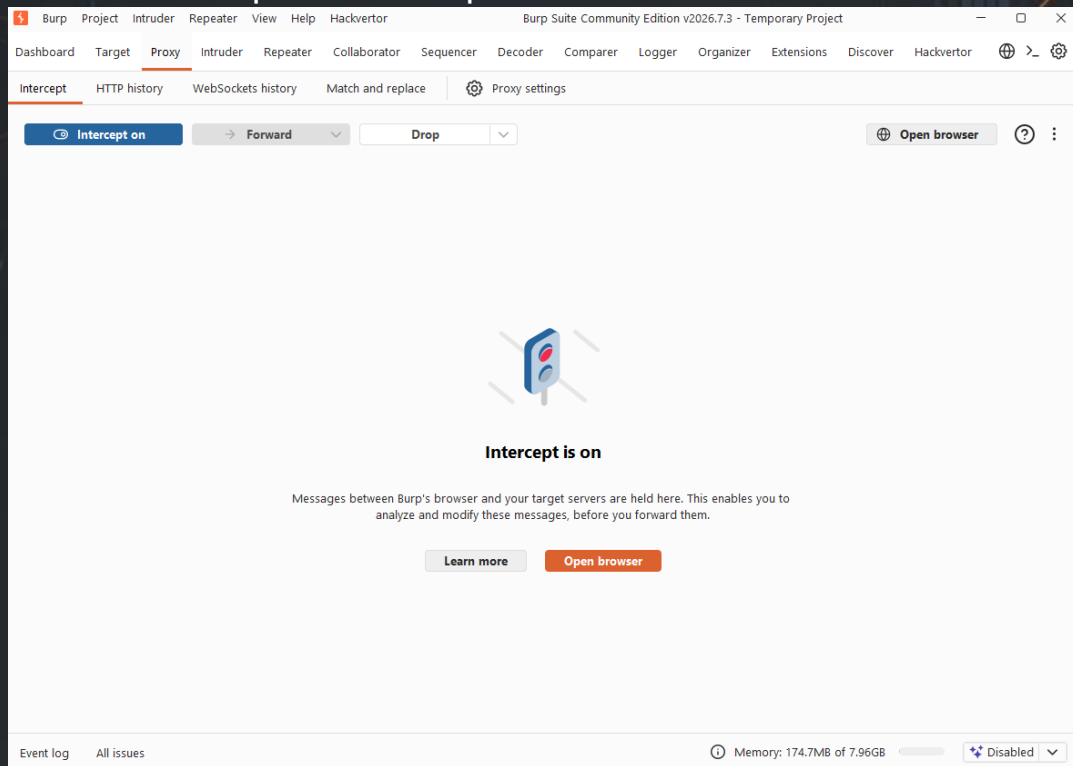
Estas vulnerabilidades permiten a un atacante leer archivos arbitrarios en el servidor que ejecuta una aplicación. Esto podría incluir:

- Código y datos de la aplicación.
- Credenciales de sistemas de back-end.
- Archivos sensibles del sistema operativo.

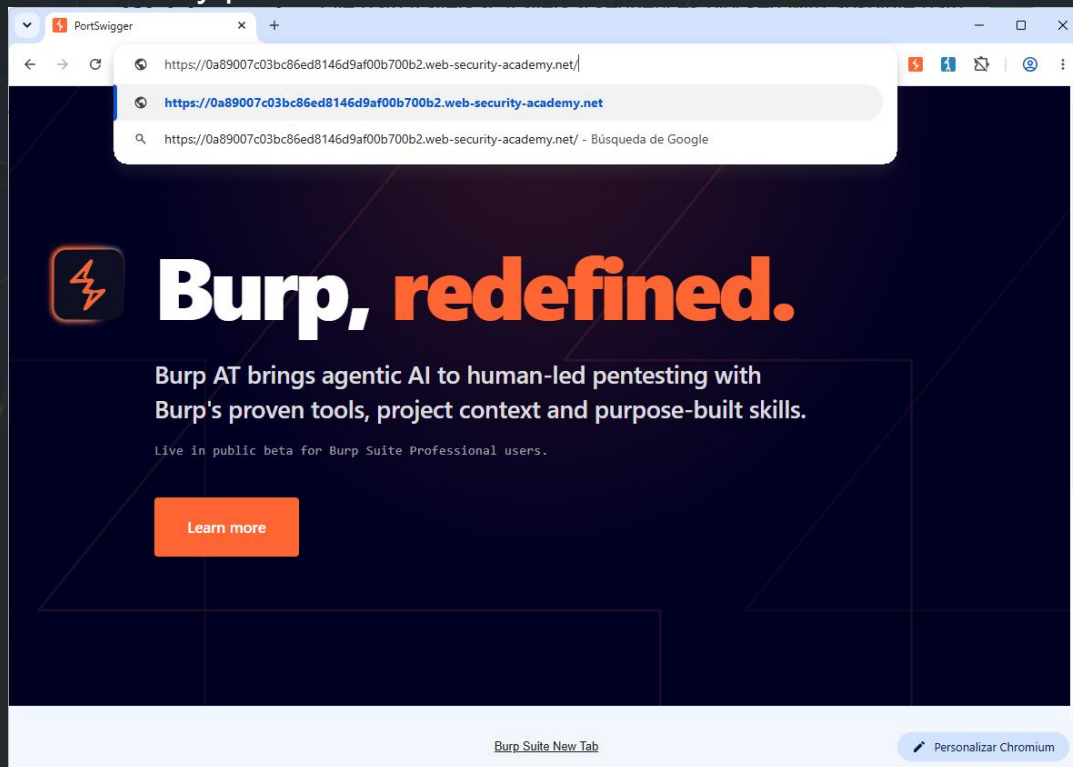
En algunos casos, un atacante podría incluso escribir en archivos arbitrarios en el servidor, lo que les permitiría modificar datos o el comportamiento de la aplicación y, finalmente, tomar el control total del servidor.

Procedimiento paso a paso

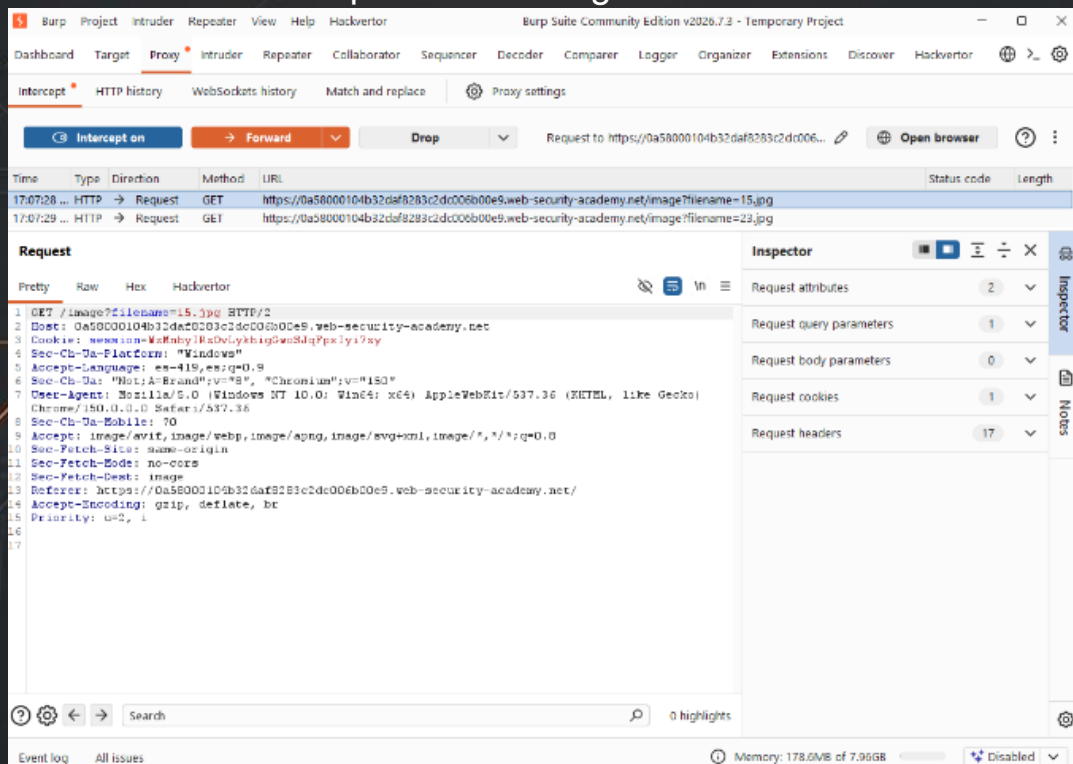
1. Abrir Burp Suite nos dirigimos a la pestaña Proxy.
2. Activamos la opción Intercept on.



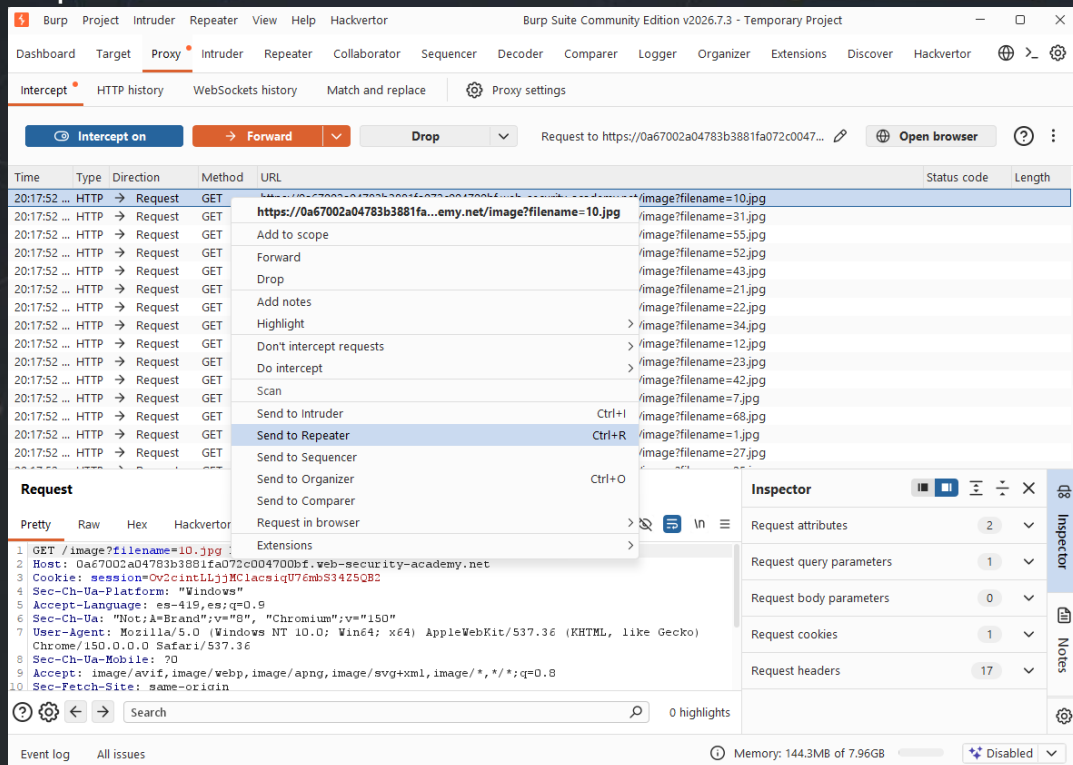
3. Dar clic en Open browser y pegar en este la dirección del laboratorio y presionar la tecla enter.



4. Regresar a Burp Suite y dar clic en Forward hasta que logremos ver la URL con el request de la imagen.



5. Dar clic con botón derecho al Request y dar clic en Sent to Repeater.



6. Dar clic en la pestaña Repeater.

7. En el apartado Reuquest logramos ver GET /image?filename=xxxx.jpg .

8. Borramos el nombre de la imagen e introducimos el Payload: ../../../../etc/passwd%00.jpg .

9. Dar clic en Send, del lado derecho en Response podemos ver el contenido del archivo passwd.

The screenshot shows the Burp Suite interface with the 'Repeater' tab selected. The target is `https://0ade00b604efa86780ff3f6c0019006f.web-security-academy.net`. The 'Request' pane shows a GET request for `/image?filename=../../../../etc/passwd&00.jpg`. The 'Response' pane shows the resulting HTTP 200 OK response, which is a JPEG image of the `passwd` file content. The 'Inspector' pane on the right shows the request and response details.

10. Con esto logramos resolver el laboratorio.

The screenshot shows the 'File path traversal, validation of file extension with null byte bypass' lab solution page on the Web Security Academy website. The page displays a congratulatory message 'Congratulations, you solved the lab!' and a 'Solved' status. Below the message is a 'SHOP' section with four items for sale: 'ZZZZZZ Bed - Your New Home Office' for \$68.78, 'Com-Tool' for \$34.62, 'The Bucket of Doom' for \$46.86, and 'Hologram Stand In' for \$73.73. Each item has a 'View details' button.

Explicación del payload

La aplicación requiere que el nombre del archivo de la petición termine con una extensión configurada, por ejemplo .jpg aquí usamos un byte nulo para finalizar correctamente la ruta del archivo antes de la extensión requerida. La aplicación valida esta la extensión sin embargo la petición de archivo omitirá todo lo que esta después del byte nulo **%00** por lo cual cargará el archivo passwd, el payload a utilizar sería el siguiente: ../../../../etc/passwd%00.jpg.

Mitigación recomendada

La forma más efectiva de prevenir path traversal es evitar pasar datos proporcionados por el usuario a las APIs del sistema de archivos por completo. Muchas funciones de la aplicación que hacen esto se pueden reescribir para ofrecer el mismo comportamiento de manera más segura.

Si no puedes evitar pasar datos del usuario a las APIs del sistema de archivos, recomendamos usar dos capas de defensa para prevenir ataques:

- Valida la entrada del usuario antes de procesarla. Idealmente, compara la entrada con una lista blanca de valores permitidos. Si eso no es posible, verifica que la entrada contenga solo contenido permitido, como caracteres alfanuméricos.

- Después de validar la entrada proporcionada, añade la entrada al directorio base y usa una API del sistema de archivos de la plataforma para canonizar la ruta. Verifica que la ruta canonizada comience con el directorio base esperado.

Conclusiones

Al realizar los ejercicios me di cuenta lo fácil que es para un atacante realizar este ataque y la exposición de información vital para la administración del servidor, también aprendí la forma en que trabaja Burp Suite y conocer la amplia lista de laboratorios que nos ayudaran a encontrar vulnerabilidades explotables en nuestras aplicaciones web e información relevante que nos ayuda a mitigarlas.